

Your AI's Privacy Filter Speaks American.

It Missed 1 in 3 Australian IDs.

We benchmarked the PII detection engine inside everyday AI pipelines against 280 identifiers in the formats people actually write (US and Australian), then scanned a synthetic clinic's AI memory end-to-end. Measured, not guessed.

Wen-Chia “Belle” Chang · Agenvana

All data synthetic · all methods open-source and reproducible

THE ONE FINDING

We gave a standard AI privacy tool ten Tax File Numbers, written exactly the way the Tax Office prints them.

It caught zero out of ten.

Not “flagged with low confidence.” Not “mislabelled but caught.” Zero. We wrote them three digits, space, three digits, space, three digits (the format on every TFN letter the ATO has ever posted) and ran them through the most widely used open-source privacy filter in AI pipelines, in its default configuration. The configuration that ships in tutorials, quick-starts, and production RAG stacks around the world.

And when we removed the spaces, its best guess at Australia's most sensitive tax identifier was: *“US Social Security Number, 5% confident.”*

The tool is not broken. It did exactly what it was configured to do. That is the problem, because the identifiers it can't see don't disappear. They get embedded into your AI's memory, where they are hardest to find and hardest to remove.

This issue is about what the filter guarding your customers' data actually sees. Measured, not guessed.

EXECUTIVE SUMMARY

The one page to read

What we did. We benchmarked standard PII detection (Microsoft Presidio, the open-source engine embedded in countless AI data pipelines, run out of the box the way almost every deployment runs it) against 280 labelled identifiers in the formats people actually write: US Social Security numbers, US phone numbers, credit cards, and their Australian equivalents (Tax File Numbers, ABNs, Medicare numbers, Australian phone formats). We then built a synthetic Australian dental clinic's AI knowledge base, 100 fake patient records wired the way real clinics wire receptionist bots, and scanned it end-to-end. All data synthetic; all methods published and reproducible.

What we found.

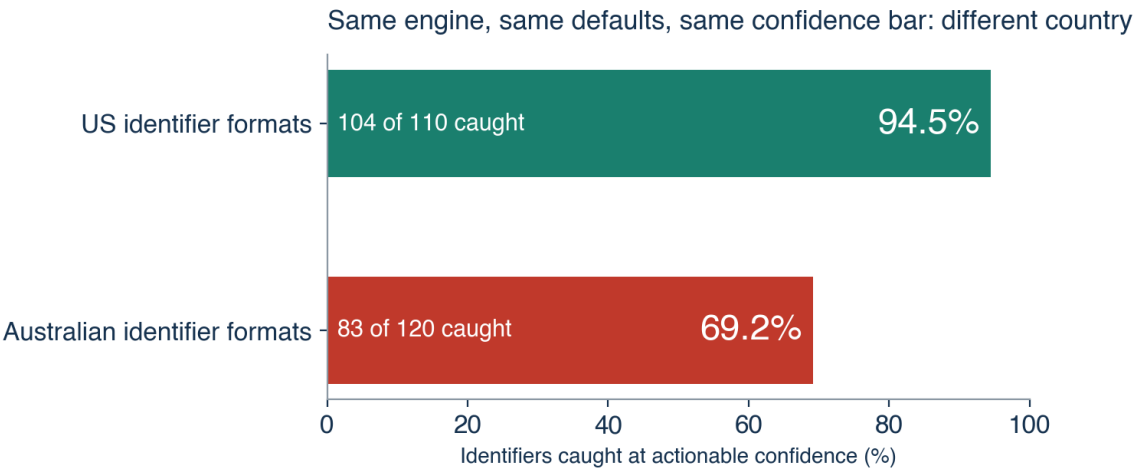
- The default configuration caught **100% of US Social Security numbers, US phones and credit cards**, and missed **1 in 3 Australian identifiers** (37 of 120, at the confidence level real systems act on).
- Tax File Numbers in the ATO's own printed format: **0 of 10 caught**. ABNs as they appear on every invoice: 1 of 10.
- In the synthetic clinic store, **37 of 100 patient records** retained at least one identifier the scan never saw: 42 identifiers in total, sitting invisibly in the AI's memory.
- The twist: the capability to catch most of this **already ships inside the tool, switched off**. Enabling the built-in Australian recognisers cut the misses from 37 to 6. The leak is not a missing technology. It is a default nobody changes.

Why this matters to you, now. Whatever your filter misses is embedded into vector databases: the memory behind chatbots, voice agents and AI search. Current research shows text can be reconstructed from those embeddings cheaply (one 2026 method needs eight model passes), extraction attacks on AI knowledge bases succeed at over 90% rates using innocent-looking questions, and the databases themselves logged three critical vulnerabilities (CVSS 9.3–9.8) in the past year. Meanwhile the regulatory clock is running: new Australian Privacy Principle transparency obligations land **10 December 2026**, and European regulators have already said models from which personal data can be extracted are not anonymous.

The good news. This is one of the rare security problems that is mostly *configuration, not capability*. Page 8 is a practical checklist: know what flows into your AI's memory, switch on the recognisers for your country, measure your filter against your own data formats before trusting it, and scrub before (not after) you embed.

THE FINDING

Your filter was tuned for someone else's country



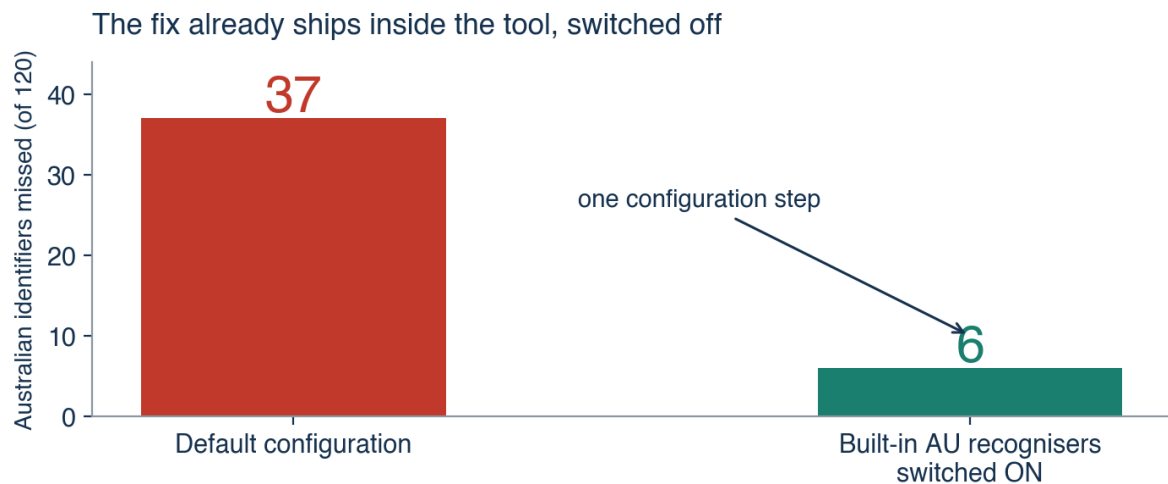
US formats it was tuned for: SSNs 30/30, phones 50/50, credit cards 30/30 (100%). The US bar dips to 94.5% only because of medical record numbers (p.5).

Where the misses concentrate. Not at the exotic edges. At the most official formats in the country:

Identifier, written the everyday way	Default config caught
Tax File Number, ATO print format (123 456 782)	0 / 10
ABN, invoice format (51 824 753 556)	1 / 10
ABN, unspaced	4 / 10
TFN, unspaced	5 / 10
Medical record number (MRN-482913)	4 / 10 (only by accident)
1300/1800 numbers · +61 international	8 / 10 each
Medicare number	9 / 10

What the “catches” actually were. Labels matter, because retention and redaction decisions key on them. An Australian landline was flagged as a *date* (85% confident). A chart number, MRN-482913, was flagged as a *person's name*. A bare TFN's only trace in the output was “US SSN / US passport / US bank number, 5% confident”: the tool reaching for the only vocabulary it was given. It does not have Australia in its vocabulary unless you put it there.

The configuration twist, and the honest core of this report. Presidio *ships* Australian recognisers: TFN, ABN, ACN, Medicare, with proper checksum validation. They are simply **not loaded by default**, and the phone recogniser defaults to US regions. One explicit configuration step took Australian recall from 69.2% to 95.0%, with misses down from 37 to 6.



The remaining 6 misses are phone formats (+61 international, 1300/1800) that no built-in recogniser covers.

So the finding is not “the tools are bad.” It is sharper and more fixable than that: **the industry's default privacy configuration encodes one country's paperwork**, every tutorial and integration propagates the default, and nobody's onboarding checklist says *“tell your privacy filter what country your customers live in.”*

This is not our fixture being unkind. Two independent 2026 academic benchmarks found the same shape at larger scale: across 25 languages and 4,127 identifier surface-forms, Presidio's recall on high-sensitivity entities was **0.07** (REDACT); across 2.37M annotated sequences and 48 PII types, the best rule-based system's span-level F1 was **0.14** (PIIBench). Our 1-in-3 number is, if anything, the *conservative* end. We measured a narrow, well-structured slice and scored generously: any overlapping detection counted, whatever the label.

HOW WE MEASURED

Method, honestly stated

- **The fixture:** 280 synthetic sentences, each containing exactly one identifier at a known position, across 28 format variants, 10 instances each. Identifiers are fake but structurally real: TFNs and ABNs carry valid checksums, credit cards pass Luhn, phone numbers use reserved fictional ranges. No real person's data anywhere.
- **The engine under test:** Microsoft Presidio with the small spaCy English model, out of the box ("default"), and with its optional Australian recognisers explicitly enabled ("configured"). The same NLP model in every configuration, so the measured gap is recogniser coverage (the thing defaults control), not model size.
- **Scoring, deliberately generous to the tool:** an identifier counts as caught if *any* detection overlaps it, even a phone number flagged as a date. Real pipelines that act on labels would do worse than our numbers. We report at "actionable confidence" (score ≥ 0.4 , the range Presidio's own sample configurations treat as decision-worthy). At the anything-at-any-confidence tier, the default's Australian recall rises only to 80.8%: still 1 in 5 missed, even counting 5%-confidence noise as a catch.
- **The clinic store:** 100 seeded synthetic patient records (name, email, phone, date of birth, Medicare number and address embedded in free-text appointment notes, the real-world anti-pattern), loaded into a Chroma vector database and scanned end-to-end through the same pipeline a real deployment would use.
- **Limitations, plainly:** the fixture is synthetic and small-n per variant (10). The categorical results (0/10, 1/10, 37/120) are robust; decimal points are not. Sentences include natural context words ("TFN", "Medicare"), which *helps* context-aware detection: conservative again. A larger NLP model would modestly improve name and location detection, but not the pattern-based identifiers where the gap lives.
- **Reproduce it:** both scripts are open source with fixed seeds, so the numbers are identical on every run: `benchmark.py` and `clinic_eval.py` in the RAGLeakGuard repository (github.com/Agenvana/RAGLeakGuard). We benchmarked our own scanner alongside. It shares the same engine and the same lesson: without its Australian pack enabled, it misses local formats too. This is a *defaults* problem across the ecosystem, ours included.

WHAT IT MEANS

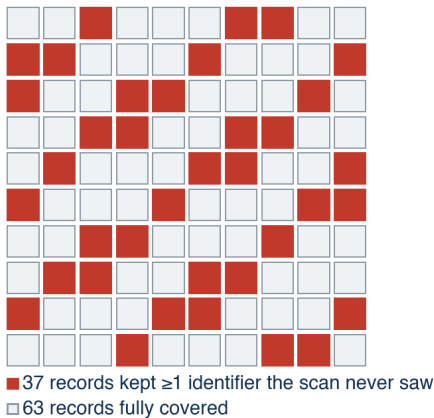
Consequence, by sector

First, the honest frame. There is no publicly documented breach of a vector database yet, and that should worry you rather than comfort you. Breach disclosures never specify “the attacker took the embedding store”; no forensic tooling looks there; most victims don't know their chatbot *has* one. Absence of headlines is absence of instruments, not absence of events. What we *can* document: the stores are attackable (three critical CVEs in twelve months: Milvus authentication bypass, CVSS 9.3; LangChain serialization injection, 9.3; LlamaIndex vector-store SQL injection, 9.8, the last one readable cross-tenant). The contents are recoverable: embedding inversion now works few-shot, and one 2026 method reconstructs text in eight forward passes, code public. And knowledge bases can be siphoned through perfectly innocent-looking questions at over 90% success rates. Every attack class has a silent period: misconfigured cloud buckets were a known risk for a decade before the headline era. This is year two of this curve.

Health: the clinic story

We built what thousands of clinics are buying right now: an AI receptionist's memory. 100 patient records (names, dates of birth, Medicare numbers, contact details) embedded in appointment notes, exactly as real front-desk software writes them. Then we ran the standard privacy scan, default settings, and asked: what did it miss?

100 synthetic patient records, scanned with default settings



42 identifiers invisible in total, most often Medicare numbers (15) and phone numbers (18). Fake data throughout; built the way real clinics wire receptionist bots.

A practice owner reading a “scan complete — clean” report would file it and move on. The 42 invisible identifiers stay embedded. For a clinic this is not abstract: under the Privacy Act, Medicare numbers are government identifiers with special handling rules, health information is sensitive information, and the OAIC has already said AI-generated content about an identifiable person is itself personal information. The notifiable data breaches scheme does not have an exemption for “our scanner didn't see it.”

Legal

A law firm's AI memory holds something clinics' doesn't: *the fact of the relationship itself*. Matter notes carry TFNs and ABNs (conveyancing, family law, estates), the exact formats measured above at zero-and-one-in-ten detection. The quieter exposure is the relationship: in a family-law or criminal matter, mere confirmation that a person is a client is leverage in the wrong hands. An embedding that surfaces matter details may expose material a firm is obliged to protect, and an inadvertent disclosure could waive protections a client depends on. A firm cannot assess that risk while its scanner reports “clean” on formats it cannot see.

Financial services & brokers

I know how this supply chain works because I have been inside it: I once paid a fake electricity bill myself. The PDF was perfect (right logo, right layout, plausible amount), and I only found out when the real provider wrote two months later asking why I had not paid. I was not careless. The reference number changes on every legitimate bill anyway, so a new number raised no suspicion at all; the scam was engineered against the exact trust cues the system itself had taught me.

That is what leaked data is for. A scam invoice is credible in exact proportion to the accurate personal data behind it: right name, right lender, right account format, plausible amount. Loan files are identifier-dense by design (TFNs, ABNs, bank details, payslips, utility bills as address proof), and leaked identifiers are the raw material of the fraud that follows. Data leaks don't hurt people directly; they arm the scam that does, months later, wearing someone else's logo. When that wave hits your customers, the investigation walks backwards to the leak, and “our privacy filter was configured for American paperwork” is not a sentence anyone wants in a regulator's findings. New APP automated-decision transparency obligations arrive **10 December 2026**; in Europe, the EDPB has stated that models from which personal data can be extracted are generally *not* anonymous. GDPR follows the data into the embedding.

WHAT TO DO

Six steps: doable this week, most of them free

1. **Inventory the funnel.** List every place free text about customers enters an AI system: chatbot conversations, call transcripts, CRM notes, email threads fed to “AI search.” That list is your embedding exposure map. If a record type on it contains identifiers, assume they are in your vector store now.
2. **Tell your filter what country it works in.** If you use Presidio or a wrapper: the Australian recognisers exist. Add them (`AuTfnRecognizer`, `AuAbnRecognizer`, `AuAcnRecognizer`, `AuMedicareRecognizer`) and set phone regions to include AU. One configuration step; in our benchmark it cut misses from 37 to 6. Whatever tool you use, the question to your vendor is one sentence: *“Which country’s identifier formats is the PII filter configured for?”*
3. **Measure before you trust.** Take 20 fake identifiers in *your* formats (our scripts generate checksum-valid ones), plant them in realistic sentences, run your pipeline’s filter, count. Twenty minutes. If the recall number surprises you, it was about to surprise you in production instead.
4. **Scrub before you embed: placement matters.** Independent research confirms what the architecture implies: redacting at the retrieval store beats redacting at the answer. Once identifiers are embedded, copied and backed up, there is no clean undo.
5. **Treat the vector store as a PII store.** Access controls, patching (the three CVEs opposite all have fixed versions), backups in scope for breach response, and a line in your incident-response plan that says the embedding store gets examined too.
6. **Put the dates in the calendar.** APP automated-decision transparency: 10 December 2026 (OAIC guidance expected September). If you have EU customers: the EDPB anonymity test already applies to you.

APPENDIX

Methodology detail & sources

Benchmark summary (280 labelled items, 28 format variants, seed fixed for identical numbers on every rerun; “caught” = any overlapping detection at score ≥ 0.4):

Category / format variant	Default	AU recognisers ON
US SSN (dashed / spaced / bare)	30/30	30/30
US ITIN (dashed / bare)	20/20	20/20
US phone (5 formats)	50/50	50/50
Credit card (3 formats)	30/30	30/30
Email / personal name	20/20	20/20
AU phone (6 formats)	55/60	55/60
AU Medicare (spaced / bare)	18/20	19/20
AU TFN (spaced / bare)	5/20	20/20
AU ABN (spaced / bare)	5/20	20/20
Medical record number	4/10	4/10
TOTAL (actionable confidence)	237/280 (84.6%)	268/280 (95.7%)

Clinic scan summary (100 records, 600 known PII items, end-to-end through a Chroma vector store): default configuration caught 558/600 items (93.0%), leaving 42 invisible; per type: names 98/100, emails 100/100, phones 82/100, dates of birth 100/100, Medicare numbers 85/100, addresses 93/100. With the Australian pack enabled: 577/600 (96.2%), 23 invisible, 78/100 records fully covered. The residue is local-format phone numbers without an area code and some rural addresses, a gap we’ve logged against our own tool’s roadmap.

False-positive pressure: at the same confidence tier the default configuration also produced 89 off-target findings across the 280 sentences (74 of them labelling the words “TFN”, “ABN” or “SSN” as organisations): noise that trains teams to ignore reports. Our configured scanner produced 0.

Sources. REDACT: arXiv:2606.19881 · PII Bench: arXiv:2604.15776 · ALGEN few-shot inversion: arXiv:2502.11308 · Diffusion embedding inversion: arXiv:2602.11047 · Vec2Text replication: arXiv:2507.07700 · IKEA benign-query extraction: arXiv:2505.15420 · Anonymization placement in RAG: arXiv:2604.15958 · CVE-2025-64513 (Milvus) · CVE-2025-68664 (LangChain) · CVE-2025-1793 (LlamaIndex) · OAIC, Guidance on privacy and commercially available AI products · EDPB Opinion 28/2024 & AI Privacy Risks in LLMs (Apr 2025).

Reproduction. scripts/benchmark.py and clinic_eval.py, fixed seeds, at github.com/Agenvana/RAGLeakGuard. Raw per-item results published alongside this report.

About

The AI Data Security Report is a monthly, methods-open report on where AI pipelines actually leak data. Measured, not guessed. It never names a villain it hasn’t benchmarked and never states a number it can’t reproduce. Author: **Wen-Chia “Belle” Chang**, Agenvana. Contact: via LinkedIn (Belle Chang) or github.com/Agenvana.

Issue #2 (August 2026), “*The Erasure Illusion*”: we test what “delete” actually deletes in AI memory.